AI Agent Red Team Checklist (Mapped to NIST AI RMF)

How to use this

- Treat each checklist item as verifiable evidence
- "Yes" means tested with findings recorded
- "No" means a red team gap
- "N/A" must be justified
- Findings should feed directly into mitigation and monitoring

1. GOVERN — Organizational readiness & accountability

Are red teaming roles, authority, and escalation paths clearly defined?

NIST emphasizes governance as foundational—without it, testing results are ignored or misused. [nist.gov]

Governance checklist

- Red teaming responsibilities are formally assigned (owner, executor, reviewer)
- AI agent use case has a named **risk owner**
- Approval authority for high-risk agent actions is documented
- Red team findings have a defined escalation path
- "Never-allowed" agent behaviors are documented
- Kill-switch or shutdown authority is clearly assigned
- Red teaming is required before **initial release**
- Red teaming is required after **material changes** (model, tools, permissions)
- Red team evidence is retained for audit and compliance
- Executive stakeholders review critical findings

✅ **Evidence examples**: RACI, policies, decision logs, risk acceptance sign-off

2. MAP — Risk identification & context definition

Do you understand what could go wrong with this agent in its real context?

NIST stresses that AI risks are **context-dependent**, especially for generative and autonomous systems. [nist.gov], [learn.microsoft.com]

Context & attack surface checklist

- Agent purpose and intended outcomes are documented
- In-scope and out-of-scope behaviors are defined
- Agent autonomy level is explicitly stated
- All tools the agent can access are enumerated
- All data sources (read/write) are documented
- Permission and identity boundaries are mapped
- Irreversible or high-impact actions are identified
- Human-in-the-loop assumptions are documented
- Long-term memory usage and retention are documented
- External dependencies (APIs, SaaS, users) are captured

✅ **Evidence examples**: architecture diagrams, threat models, permission maps

©2026 CoolUnderFire Cybersecurity, LLC

3. MEASURE — Adversarial testing & evaluation

Have you actually tried to make the agent fail in realistic ways?

NIST treats red teaming as part of **risk measurement**, complementing automated evaluations and metrics. [nist.gov], [cdn.openai.com]

Core red team testing checklist (agents)

A. Goal & instruction manipulation

- Tested conflicting or ambiguous goals
- Tested urgency-based priority overrides
- Tested subtle safety de-prioritization prompts
- Tested multi-turn instruction drift

B. Tool misuse & chaining

- Tested unauthorized tool use
- Tested safe-tool → unsafe-outcome chaining
- Tested retry loops that escalate risk
- Tested inferred or hallucinated tool capabilities

C. Permission & identity abuse

- Tested acting on behalf of the wrong user
- Tested privilege escalation attempts
- Tested assumption of implied access
- Tested least-privilege violations

D. Memory & persistence attacks

- Tested memory poisoning
- Tested unsafe instructions stored long-term
- Tested cross-session or cross-user leakage
- Tested memory replay after context changes

E. Autonomy & time-based failure

- Tested long-running autonomous tasks
- Tested compounding small errors over time
- Tested goal drift after partial success
- Tested delayed harmful actions

F. Human-in-the-loop failure

- Tested approval fatigue scenarios
- Tested persuasive or over-confident language
- Tested unclear or misleading risk warnings
- Tested default “approve” UX paths

✅ **Evidence examples**: red team logs, transcripts, attack scripts, automated scan reports

4. MANAGE — Mitigation, monitoring & lifecycle control

Are failures contained, corrected, and prevented from recurring?

©2026 CoolUnderFire Cybersecurity, LLC

NIST requires that identified risks be **managed over time**, not just discovered. [nist.gov]

Mitigation & control checklist

- Critical failures block release
- High-risk failures have documented mitigations
- Risk acceptance is formally approved where used
- Hard technical controls exist (not prompt-only)
- Tool allowlists / denylists are enforced
- Action-level approvals are enforced for high-impact actions
- Memory write filters or validation exist
- Autonomous actions are scoped or time-boxed
- Human override or kill-switch is tested
- Monitoring covers autonomous and tool actions
- Alerts exist for abnormal behavior patterns
- Red team tests are re-run after mitigations
- Continuous or periodic red teaming is scheduled

✅ **Evidence examples**: control configs, monitoring alerts, regression test results

Cross-cutting: Generative AI–specific expectations (NIST-AI-600-1)

NIST's Generative AI Profile reinforces adversarial testing for misuse, drift, and autonomy. [nist.gov]

- Misuse scenarios are explicitly tested
- Agent behavior under stress or edge cases is tested
- Post-deployment monitoring for emergent risk exists
- Feedback loops from incidents → red teaming → mitigations exist

Executive summary checkbox (for leadership)

You should be able to truthfully say:

- We understand our agent's risk surface
- We have tried to break it like an attacker would
- We know what failure looks like
- We can stop or contain harm
- We will retest as the agent evolves

©2026 CoolUnderFire Cybersecurity, LLC